ANNEXE D

Analyse de risque

Version : 1.0

Classification : Interne

Statut : Approuvée

Auteur : Consultant Cybersécurité

Approbateur : Direction Générale — Antoine Verger

Historique des versions

Version	Date	Auteur	Description
0.1	15/06/2026	Consultant cybersécurité	Création du document
0.9	20/06/2026	DSI	Relecture technique
1.0	30/06/2026	Direction Générale	Validation officielle

Diffusion

Destinataire	Diffusion
Direction Générale	Oui
DSI	Oui
Responsable RH	Oui
DPO	Oui
Équipe informatique	Oui
Managers	Oui
Collaborateurs	Version adaptée

Confidentialité

Ce document est destiné exclusivement aux personnes autorisées par BioMarket. Il ne peut être diffusé sans l'accord de la Direction.

1. Analyse des risques selon la méthode EBIOS Risk Manager

1.1 Choix de la méthode

Objectif

La mise en œuvre d'un SMSI conforme à la norme ISO/IEC 27001 nécessite d'identifier, d'évaluer et de traiter les risques susceptibles d'affecter les actifs informationnels de l'organisation.

Pour répondre à cet objectif, BioMarket s'appuie sur la méthode **EBIOS Risk Manager (EBIOS RM)**, développée par l'ANSSI en collaboration avec le Club EBIOS. Cette méthode fournit un cadre structuré pour analyser les risques numériques, identifier les scénarios d'attaque et définir les mesures de sécurité adaptées. Elle peut notamment être utilisée dans le cadre d'un SMSI conforme à l'ISO/IEC 27001.

Contrairement à une approche uniquement technique, EBIOS RM adopte une vision globale du risque en s'appuyant sur les activités critiques de l'organisation, les parties prenantes de son écosystème et les scénarios de menace susceptibles de compromettre les objectifs de l'entreprise.

Principes de la méthode

La méthode EBIOS Risk Manager repose notamment sur les principes suivants :

- une approche orientée vers les risques numériques et les attaques intentionnelles ;
- une vision à la fois stratégique et opérationnelle des risques ;
- une démarche collaborative impliquant les métiers, la DSI, la Direction et les acteurs de la cybersécurité ;
- une analyse fondée sur des scénarios de risques plutôt que sur une simple liste de vulnérabilités ;
- une démarche itérative permettant de mettre à jour l'analyse en fonction de l'évolution du contexte de l'organisation.

Ces principes permettent d'adapter l'analyse des risques au contexte et aux enjeux propres à BioMarket.

Les cinq ateliers d'EBIOS RM

L'analyse des risques est conduite selon les cinq ateliers définis par la méthode EBIOS Risk Manager :

Atelier	Objectif
Atelier 1 – Cadrage et socle de sécurité	Définir le périmètre de l'étude, les valeurs métier, les biens supports et le socle de sécurité existant.
Atelier 2 – Sources de risque	Identifier les sources de risque susceptibles de menacer les activités de BioMarket et les objectifs visés.
Atelier 3 – Scénarios stratégiques	Construire les scénarios stratégiques en tenant compte des parties prenantes critiques de l'écosystème.
Atelier 4 – Scénarios opérationnels	Élaborer les scénarios opérationnels décrivant les modes opératoires techniques pouvant être utilisés par un attaquant.
Atelier 5 – Traitement du risque	Évaluer les risques, définir les stratégies et mesures de traitement et assurer le suivi des risques résiduels.

Cette démarche permet de hiérarchiser les risques et de définir les mesures de sécurité adaptées aux enjeux identifiés.

Application à BioMarket

Dans le cadre de ce projet, la méthode EBIOS RM est appliquée au périmètre du SMSI défini précédemment.

L'analyse porte notamment sur les processus critiques de BioMarket, les données sensibles relatives aux clients, aux ressources humaines et à l'activité commerciale, les infrastructures informatiques ainsi que les interactions avec les parties prenantes essentielles, notamment le prestataire **Iron4Software** chargé du développement de la plateforme e-commerce.

Les ateliers suivants présentent successivement le cadrage et le socle de sécurité, les sources de risque, les scénarios stratégiques, les scénarios opérationnels et le traitement des risques.

2. Atelier 1 – Cadrage et socle de sécurité

Objectif de l’atelier

Le premier atelier d’EBIOS Risk Manager consiste à définir le contexte de l’étude, le périmètre de l’analyse des risques, les valeurs métier à protéger, les biens supports ainsi que le socle de sécurité existant.

Cette étape permet d'établir un socle commun avant d'identifier les sources de risque et les scénarios susceptibles d'affecter BioMarket. Elle s'appuie sur les travaux réalisés lors de l'analyse du contexte et de la définition du périmètre du SMSI.

2.1 Périmètre

L'analyse des risques porte sur le périmètre du SMSI défini dans le cadre du projet de certification ISO/IEC 27001.

Le périmètre étudié comprend notamment :

- le site principal de Tourcoing ;
- les magasins BioMarket connectés au système d'information ;
- les utilisateurs internes et leurs postes de travail ;
- l'Active Directory centralisé ;
- les serveurs physiques et virtuels ;
- les infrastructures réseau et les équipements de sécurité ;
- le stockage local et le stockage Cloud ;
- les applications métiers ;
- les données clients, RH, fournisseurs, comptables et commerciales ;
- les accès distants réalisés via le VPN SSL ;
- **les échanges entre le SI interne et la plateforme e-commerce via les API REST sécurisées ;**
- **les relations avec les prestataires, notamment Iron4Software.**

La plateforme e-commerce constitue un composant du système d'information de BioMarket et est intégrée au périmètre du SMSI. Bien que développée et hébergée par Iron4Software sur une infrastructure PaaS, elle est soumise aux exigences de sécurité définies par BioMarket, notamment en matière de Security by Design, de gestion des accès, de protection des données, de gestion des vulnérabilités et de validation avant mise en production. L'infrastructure physique et les composants internes d'Iron4Software restent hors du périmètre de certification, leur administration relevant du prestataire.

2.2 Valeurs métier

Les valeurs métier représentent les activités, processus et informations essentiels au fonctionnement de BioMarket et dont la compromission ou l'indisponibilité pourrait avoir un impact significatif sur l'entreprise.

L'analyse permet d'identifier les valeurs métier suivantes :

Valeur métier	**Importance**
Vente de produits biologiques	Critique
Gestion des commandes	Critique
Gestion des stocks	Critique
Gestion des ressources humaines	Importante
Gestion financière	Critique
Relation client	Critique
Plateforme e-commerce	Critique

Toute indisponibilité, altération ou compromission de ces valeurs métier pourrait avoir un impact significatif sur la continuité des activités, les opérations commerciales, la protection des données et la conformité réglementaire de BioMarket.

2.3 Biens supports

Les biens supports correspondent aux ressources nécessaires au fonctionnement et à la protection des valeurs métier. Ils peuvent être techniques, informationnels, humains ou organisationnels.

Biens supports techniques

- Active Directory ;
- serveurs physiques et virtuels ;
- postes de travail ;
- switches réseau ;
- pare-feu Fortinet ;
- VPN SSL ;
- réseau local et VLAN ;
- stockage local ;
- stockage Cloud ;
- applications métiers ;

- Plateforme e-commerce / environnement PaaS / services du prestataire Iron4Software
- outils d’administration ;
- équipements réseau nécessaires aux communications entre les différents composants du SI.

Biens supports informationnels

- données clients ;
- données RH ;
- données commerciales ;
- données financières ;
- données fournisseurs ;
- documents internes ;
- journaux d'événements.

Biens supports humains

- Direction générale ;
- DSI ;
- DPO ;
- administrateurs système ;
- collaborateurs ;
-
- responsables de magasins ;
- prestataire Iron4Software.

2.4 Événements redoutés

La gravité mesure le niveau des conséquences d'un événement redouté sur les valeurs métier de BioMarket. L'échelle retenue comporte quatre niveaux.

Niveau	Intitulé	Conséquence
G4	Critique	Incapacité à assurer tout ou partie de l'activité, avec des impacts graves sur les personnes, les biens ou la pérennité de l'organisation.
G3	Grave	Forte dégradation des performances de l'activité, avec des impacts significatifs et un fonctionnement en mode très dégradé.
G2	Significative	Dégradation des performances de l'activité sans impact majeur sur les personnes ou les biens ; fonctionnement possible en mode dégradé.
G1	Mineure	Absence d'impact opérationnel significatif ; situation absorbable par l'organisation.

Cette échelle est ensuite appliquée aux différents événements redoutés identifiés pour les valeurs métier de BioMarket. La gravité de chaque événement est déterminée en fonction de ses impacts potentiels sur l'activité, les personnes, les données, les aspects financiers et l'image de l'entreprise.

Valeur métier	**Événement redouté**	**Impacts**	**Gravité**
Vente de produits biologiques	Interruption des ventes pendant une durée importante	■ Impacts financiers ■ Impacts sur l'activité ■ Impacts sur l'image et la confiance des clients	**G3 – Grave**
Gestion des commandes	Altération des commandes entraînant des erreurs de préparation ou de livraison	■ Impacts financiers ■ Impacts sur la satisfaction client ■ Impacts sur l'image et la confiance	**G3 – Grave**
Gestion des stocks	Perte ou altération des informations de stock entraînant une indisponibilité ou une mauvaise gestion des produits	■ Impacts sur l'activité ■ Impacts financiers ■ Impacts sur la relation client	**G2 – Significative**
Gestion des ressources humaines	Divulgation ou perte de confidentialité des données des salariés	■ Impacts sur les personnes ■ Impacts juridiques /	**G3 – Grave**

Valeur métier	Événement redouté	Impacts	Gravité
		RGPD ■ Impacts sur l'image	
Gestion financière	Altération ou perte des informations financières	■ Impacts financiers ■ Impacts sur les obligations réglementaires ■ Impacts sur l'activité	**G3 – Grave**
Relation client	Divulgation des données personnelles des clients	■ Impacts sur les personnes ■ Impacts juridiques / RGPD ■ Impacts sur l'image et la confiance	**G4 – Critique**
Plateforme e-commerce	Indisponibilité de la plateforme entraînant une interruption des ventes en ligne	■ Impacts financiers ■ Impacts sur l'activité ■ Impacts sur l'image et la confiance des client	**G3 – Grave**

2.5 Socle de sécurité existant

L'analyse de l'existant met en évidence plusieurs mesures de sécurité déjà déployées au sein de BioMarket :

Mesure existante	État constaté
Pare-feu Fortinet	En place
Active Directory centralisé	En place
Segmentation réseau par VLAN	En place
VPN SSL pour les accès distants	En place
Authentification par certificat	En place
MFA pour les comptes à privilèges	En place
Politique de mots de passe renforcée	En place
Stockage Cloud chiffré	En place

Plusieurs écarts restent cependant à traiter, notamment :

- la généralisation du MFA à l'ensemble des comptes concernés ;
- la revue périodique des habilitations ;
- la gestion des comptes des collaborateurs ayant quitté l'entreprise ;
- la protection des données stockées localement ;
- la sensibilisation des utilisateurs ;
- la centralisation et l'exploitation des journaux de sécurité ;
- la formalisation des dispositifs de sauvegarde et de restauration ;
- la sécurisation des accès et échanges avec les prestataires.

Ce socle constitue le niveau de sécurité initial à partir duquel les scénarios de risque seront étudiés. Les mesures déjà en place sont prises en compte dans l'évaluation afin de ne pas considérer BioMarket comme dépourvue de dispositifs de sécurité.

3. Atelier 2 – Sources de risque

Objectif de l'atelier

Le deuxième atelier de la méthode EBIOS Risk Manager consiste à identifier et caractériser les **sources de risque (SR)** susceptibles de porter atteinte aux valeurs métier et aux biens supports de BioMarket.

Pour chaque source de risque, les **objectifs visés (OV)** sont identifiés afin de déterminer les couples SR/OV les plus pertinents pour la suite de l'analyse.

Cet atelier permet ainsi de répondre à la question : **« Qui est la menace ? »** et de sélectionner les menaces prioritaires qui seront étudiées dans les scénarios stratégiques.

3.1 Sources de risque

L'analyse du contexte de BioMarket permet d'identifier les principales sources de risque suivantes :

Source de risque	Description	Motivation principale
Cybercriminels	Acteurs externes recherchant un gain financier par le vol de données, l'extorsion ou le rançongiciel.	Financière
Employé malveillant	Collaborateur utilisant volontairement ses accès à des fins frauduleuses.	Vengeance, profit
Employé négligent	Collaborateur provoquant une erreur ou une exposition de données par mauvaise manipulation ou non-respect des procédures.	Accidentelle
Prestataire compromis	Compromission d'un prestataire disposant d'une relation de confiance ou d'accès au SI.	Compromission indirecte
Fournisseur compromis	Compromission d'un partenaire externe pouvant constituer un vecteur d'attaque indirect.	Indirecte
Hacktivistes	Acteurs cherchant à porter atteinte à l'image ou aux activités de BioMarket.	Idéologique

3.2 Objectifs visés

Les principales sources de risque peuvent poursuivre différents objectifs vis-à-vis de BioMarket :

Source de risque	Objectif visé
Cybercriminels	**Obtenir un gain financier par le chiffrement ou l'extorsion**
Cybercriminels	**Voler ou exfiltrer des données clients ou RH**
Cybercriminels	**Exploiter une relation de confiance avec un prestataire**
Employé malveillant	**Accéder, modifier ou divulguer des informations sensibles**
Employé négligent	**Exposer involontairement des informations ou compromettre le fonctionnement du SI**
Prestataire compromis	**Utiliser les accès légitimes du prestataire pour atteindre les ressources de BioMarket**
Fournisseur compromis	**Introduire indirectement une compromission dans le SI**
Hacktivistes	**Porter atteinte à l'image ou à la disponibilité des services de BioMarket**

3.3 Pertinence des couples SR/OV

La pertinence des couples « Source de risque / Objectif visé » est évaluée à partir du niveau de motivation de la source de risque et des ressources dont elle dispose. La matrice ci-dessous reprend l'échelle de pertinence présentée dans la méthode EBIOS Risk Manager.

Matrice de pertinence

Motivation \ Ressources	**1 – Ressources limitées**	**2 – Ressources significatives**	**3 – Ressources importantes**	**4 – Ressources illimitées**
4 – Fortement motivée	**Moyennement pertinent**	**Plutôt pertinent**	**Très pertinent**	**Très pertinent**
3 – Assez motivée	**Moyennement pertinent**	**Plutôt pertinent**	**Plutôt pertinent**	**Très pertinent**
2 – Peu motivée	**Peu pertinent**	**Moyennement pertinent**	**Plutôt pertinent**	**Plutôt pertinent**
1 – Très peu motivée	**Peu pertinent**	**Peu pertinent**	**Moyennement pertinent**	**Moyennement pertinent**

L'analyse permet de retenir en priorité les couples suivants :

Source de risque	Objectif visé	Motivation	Ressources	Pertinence	Justification
Cybercriminels	Gain financier / rançongiciel	4	3	**Très pertinent**	Forte motivation financière et ressources techniques importantes permettant de mener des attaques ciblées.
Cybercriminels	Vol de données	4	3	**Très pertinent**	Les données clients et RH présentent une valeur importante et peuvent être exploitées à des fins financières.
Cybercriminels	Exploiter une relation de confiance avec un prestataire	4	3	**Très pertinent**	Iron4Software constitue une relation de confiance importante autour de la plateforme e-commerce.
Employé malveillant	Accéder, modifier ou divulguer des données sensibles	3	2	**Plutôt pertinent**	L'acteur dispose d'accès légitimes au SI, mais ses ressources restent inférieures à celles d'un attaquant externe spécialisé.
Employé négligent	Exposer involontairement des données ou compromettre le SI	2	2	**Moyennement pertinent**	Le risque est lié principalement aux erreurs humaines et au non-respect des procédures plutôt qu'à une volonté d'attaque.
Prestataire compromis	Utiliser des accès légitimes pour atteindre les ressources de BioMarket	3	2	**Plutôt pertinent**	Une compromission du prestataire peut permettre l'utilisation de ses accès ou de la relation de confiance avec BioMarket.

Source de risque	Objectif visé	Motivation	Ressources	Pertinence	Justification
Fournisseur compromis	Introduire indirectement une compromission dans le SI	2	2	**Moyennement pertinent**	Le scénario est possible mais l'exposition directe des fournisseurs au SI de BioMarket est plus limitée.
Hacktivistes	Porter atteinte à l'image ou à la disponibilité des services	3	2	**Plutôt pertinent**	Une motivation idéologique peut conduire à des actions contre les services exposés, mais cette menace est moins directement liée aux risques prioritaires identifiés.

Les couples évalués comme « Très pertinent » ou « Plutôt pertinent » sont retenus pour la construction des scénarios stratégiques de l'atelier 3. Les couples « Moyennement pertinent » sont conservés sous surveillance et pourront être réévalués en fonction de l'évolution du contexte de BioMarket.

3.4 Synthèse

L'analyse met en évidence trois catégories de menaces particulièrement importantes pour BioMarket :

- les **cybercriminels**, notamment en raison des risques de rançongiciel et de vol de données ;
- les **menaces internes**, qu'elles soient malveillantes ou accidentelles ;
- les **prestataires externes**, notamment Iron4Software, en raison des relations de confiance et des échanges liés au projet e-commerce.

4. Atelier 3 – Scénarios stratégiques

4.1 Identification des parties prenantes de l'écosystème

L'Atelier 3 a pour objectif d'identifier les parties prenantes internes et externes intervenant dans l'écosystème de BioMarket et susceptibles d'influencer le niveau de risque pesant sur ses valeurs métier.

L'analyse prend notamment en compte les relations de dépendance, les possibilités d'accès aux ressources de BioMarket, le niveau de maturité en cybersécurité ainsi que le niveau de confiance associé à chaque partie prenante.

Parties prenantes identifiées

Réf.	Partie prenante	Rôle dans l'écosystème
PP1	Direction générale	Pilotage stratégique et décisions de l'entreprise
PP2	DSI	Administration, exploitation et sécurité du SI
PP3	DPO	Protection des données personnelles et suivi des exigences liées au RGPD.
PP4	Collaborateurs	Utilisation quotidienne du système d'information
PP5	Responsables métiers / magasins	Réalisation des activités opérationnelles
PP6	Clients	Achats et transmission de données personnelles
PP7	**Iron4Software**	Développement et maintenance de la plateforme e-commerce
PP8	Fournisseurs	Approvisionnement et échanges de données
PP9	Hébergeur / services Cloud	Hébergement et stockage des données et services
PP10	Prestataires externes	Fourniture de services à BioMarket
PP11	Autorités réglementaires	Contrôle du respect des obligations réglementaires

Parmi ces parties prenantes, **Iron4Software constitue un élément particulièrement critique**. La société intervient dans le développement de la plateforme e-commerce et entretient une relation de confiance avec BioMarket. Cette relation peut constituer un vecteur d'attaque indirect vers les ressources liées au projet e-commerce.

Les collaborateurs représentent également une partie prenante importante en raison de leur accès quotidien au système d'information. Les services Cloud constituent quant à eux une dépendance importante pour l'hébergement et le stockage des données.

4.2 Évaluation du niveau de menace des parties prenantes

L'évaluation du niveau de menace permet d'identifier les parties prenantes de l'écosystème susceptibles de représenter une menace pour BioMarket.

Quatre critères sont pris en compte :

- **Dépendance** : importance de la relation avec la partie prenante pour l'activité de BioMarket ;
- **Pénétration** : niveau d'accès de la partie prenante aux ressources internes ;
- **Maturité cyber** : capacité de la partie prenante à maîtriser les risques de cybersécurité ;
- **Confiance** : niveau de confiance accordé à la partie prenante et compatibilité de ses intérêts avec ceux de BioMarket.

Le niveau de dangerosité est calculé selon la formule :

Niveau de dangerosité = (Dépendance × Pénétration) / (Maturité cyber × Confiance)

Cette formule correspond à celle présentée dans la fiche méthode EBIOS-RM.

Tableau 4.2 – Évaluation du niveau de menace des parties prenantes

Partie prenante	Dépendance	Pénétration	Maturité cyber	Confiance	Niveau de menace
Direction générale	2	1	3	4	**0,17**
DSI	4	4	3	4	**1,33**
Collaborateurs	3	2	2	3	**1,00**
Responsables métiers / magasins	3	2	2	3	**1,00**
Clients	2	1	3	4	**0,17**
Iron4Software	3	3	2	3	**1,50**
Fournisseurs	2	1	2	3	**0,33**
Hébergeur / services Cloud	3	4	4	4	**0,75**
Prestataires externes	2	2	2	3	**0,67**
Autorités réglementaires	1	1	4	4	**0,06**

Analyse

L'évaluation fait ressortir plusieurs parties prenantes présentant un niveau de menace significatif.

Iron4Software présente le niveau de menace le plus élevé avec une valeur de **1,50**. Son niveau de pénétration dans l'écosystème de BioMarket, associé à une maturité cyber évaluée comme perfectible, justifie une attention particulière.

La **DSI** présente également un niveau élevé (**1,33**), notamment en raison de sa forte dépendance aux activités de BioMarket et de son niveau d'accès important aux ressources du système d'information.

Les **collaborateurs** et les **responsables métiers / magasins** obtiennent chacun un niveau de **1,00**. Leur utilisation régulière du système d'information et leur accès aux ressources nécessaires à leurs activités constituent des éléments à prendre en compte dans l'analyse.

Les autres parties prenantes présentent des niveaux de menace plus faibles.

4.3 Cartographie des menaces

La cartographie des menaces permet de représenter le niveau de menace associé aux parties prenantes de l'écosystème de BioMarket. Elle permet notamment d'identifier les parties prenantes critiques qui devront être prises en compte dans la construction des scénarios stratégiques.

Le niveau de menace est traduit en trois niveaux principaux :

- **Très élevé – zone de danger** : menace difficilement acceptable ;
- **Élevé – zone de contrôle** : menace tolérable sous contrôle ;
- **Faible – zone de veille** : menace faible et acceptable en l'état ;
- les parties prenantes situées en dehors de la zone de veille présentent une menace négligeable.

Cette représentation est cohérente avec la logique de la fiche méthode EBIOS-RM, qui distingue les zones de danger, de contrôle et de veille.

Tableau 4.3 – Cartographie des menaces des parties prenantes

Partie prenante	**Niveau de menace**	**Niveaux / justification**
DSI	**Élevé**	Exposition très élevée & fiabilité cyber moyenne
Collaborateurs	**Élevé**	Exposition élevée & fiabilité cyber faible
Responsables métiers / magasins	**Élevé**	Exposition élevée & fiabilité cyber faible
Iron4Software	**Élevé**	Exposition élevée & fiabilité cyber faible
Hébergeur / services Cloud	**Faible**	Exposition élevée & fiabilité cyber élevée
Prestataires externes	**Faible**	Exposition moyenne & fiabilité cyber faible

Partie prenante	Niveau de menace	Niveaux / justification
Fournisseurs	**Faible**	Exposition faible & fiabilité cyber faible
Direction générale	**Négligeable**	Exposition faible & fiabilité cyber élevée
Clients	**Négligeable**	Exposition faible & fiabilité cyber élevée
Autorités réglementaires	**Négligeable**	Exposition très faible & fiabilité cyber élevée

Parties prenantes critiques

La cartographie fait ressortir **quatre parties prenantes situées en zone de contrôle** :

- **Iron4Software** ;
- **DSI** ;
- **Collaborateurs** ;
- **Responsables métiers / magasins**.

Elles présentent un niveau de menace suffisamment important pour être prises en compte dans l'élaboration des scénarios stratégiques. La fiche méthode précise que les parties prenantes situées dans les zones de danger et de contrôle sont considérées comme critiques et doivent être intégrées aux scénarios stratégiques.

Iron4Software constitue le principal point d'attention de l'écosystème, avec un niveau de dangerosité de **1,50** obtenu lors de l'évaluation précédente. Son niveau d'exposition et sa maturité cyber perfectible rendent particulièrement important le contrôle de ses accès et de sa relation avec BioMarket.

La **DSI** constitue également une partie prenante critique en raison de son niveau d'accès important au système d'information. Les **collaborateurs** et les **responsables métiers / magasins** représentent quant à eux des vecteurs potentiels de compromission du fait de leurs accès et de leur utilisation quotidienne du système d'information.

4.4 Construction des scénarios stratégiques

Les scénarios stratégiques sont construits à partir des couples **Source de Risque / Objectif Visé** retenus lors de l'Atelier 2 et des parties prenantes critiques identifiées lors de la cartographie des menaces.

Ils décrivent les principales étapes qu'un attaquant pourrait suivre pour atteindre son objectif. Les événements touchant l'écosystème constituent des événements intermédiaires, tandis que l'atteinte des valeurs métier constitue l'événement redouté.

4.4.1 S1 – Compromission d'Iron4Software

Source de risque : Cybercriminels
Objectif visé : Exploitation de la relation de confiance
Partie prenante critique : Iron4Software
Valeur métier ciblée : Activité e-commerce
Gravité : G3 – Grave

Chemin d'attaque

Cybercriminel
↓
Compromission d'Iron4Software
↓
Utilisation des accès légitimes du prestataire
↓
Accès à l'environnement de développement ou aux ressources associées à la plateforme e-commerce
↓
Compromission de la plateforme ou des données associées
↓
Atteinte à l'activité e-commerce

4.4.2 S2 – Compromission d'un compte administrateur

Source de risque : Cybercriminels
Objectif visé : Accès aux ressources critiques
Partie prenante critique : DSI / administrateur
Valeurs métier ciblées : Données métiers et continuité de l'activité
Gravité : G4 – Critique

Chemin d'attaque

Cybercriminel
↓
Compromission d'un compte administrateur
↓
Utilisation des privilèges associés au compte

↓

Accès aux ressources internes et à l'Active Directory

↓

Compromission potentielle d'autres comptes ou services

↓

Accès aux données et services critiques

↓

Atteinte à la confidentialité, l'intégrité ou la disponibilité

4.4.3 S3 – Fuite de données personnelles

Source de risque : Cybercriminels / employé malveillant / employé négligent
Objectif visé : Vol ou divulgation de données
Parties prenantes critiques : Collaborateurs / DSI
Acteur associé au traitement : DPO
Valeur métier ciblée : Données personnelles des clients
Gravité : G4 – Critique
Chemin d'attaque

Source de risque

↓

Compromission ou utilisation abusive d'un compte

↓

Accès non autorisé aux données personnelles

↓

Extraction ou divulgation des données

↓

Exfiltration vers un environnement externe

↓

Divulgation de données personnelles

4.4.4 S4 – Attaque par rançongiciel

Source de risque : Cybercriminels
Objectif visé : Gain financier / extorsion
Parties prenantes critiques : Collaborateurs / DSI
Valeurs métier ciblées : Données métiers, réseau et services nécessaires à l'activité
Gravité : G4 – Critique

Chemin d'attaque

Cybercriminel

↓

Compromission initiale d'un compte ou d'un poste

↓

Élévation des privilèges

↓

Propagation dans le système d'information

↓

Accès aux ressources critiques

↓

Chiffrement des données et systèmes

↓

Indisponibilité des ressources

↓

Interruption de l'activité de BioMarket

4.4.5 Synthèse des scénarios stratégiques

Scénario	Source de risque	PP critique exploitée	Objectif visé	Événement redouté	Gravité Atelier 1
S1 – Compromission d'Iron4Software	Cybercriminels	Iron4Software	Exploiter la relation de confiance	Compromission de la plateforme e-commerce	**G3 – Grave**
S2 – Compromission d'un compte administrateur	Cybercriminels	DSI	Accéder aux ressources critiques	Compromission des données et services critiques	**G4 – Critique**
S3 – Fuite de données personnelles	Cybercriminels / employé malveillant / employé négligent	Collaborateurs / DSI	Vol ou divulgation de données	Atteinte à la confidentialité des données personnelles	**G4 – Critique**
S4 – Attaque par rançongiciel	Cybercriminels	Collaborateurs / DSI	Gain financier / extorsion	Indisponibilité du SI et interruption de l'activité	**G4 – Critique**

Échelle de gravité utilisée

Niveau	Intitulé	Conséquence
G4	**Critique**	Incapacité à assurer tout ou partie de l'activité, avec des impacts graves sur les personnes, les biens ou la pérennité de l'organisation.
G3	**Grave**	Forte dégradation des performances de l'activité, avec des impacts significatifs et un fonctionnement en mode très dégradé.
G2	**Significative**	Dégradation des performances de l'activité sans impact majeur sur les personnes ou les biens ; fonctionnement possible en mode dégradé.
G1	**Mineure**	Absence d'impact opérationnel significatif ; situation absorbable par l'organisation.

5. Atelier 4 – Scénarios opérationnels

Objectif de l'atelier

Le quatrième atelier de la méthode EBIOS Risk Manager consiste à détailler les scénarios stratégiques retenus lors de l'atelier 3 en identifiant les modes opératoires susceptibles d'être utilisés par les sources de risque.

Pour chaque scénario, l'analyse porte sur les biens supports concernés, les vulnérabilités, le chemin d'attaque et la vraisemblance de réalisation.

Les scénarios opérationnels sont construits à partir des scénarios stratégiques retenus précédemment.

5.1 Scénario opérationnel 1 – Compromission d'un compte administrateur

Mode opératoire

Un attaquant adresse un courriel de phishing à un administrateur de BioMarket afin de récupérer ses identifiants.

Le compte compromis peut ensuite être utilisé pour accéder au système d'information et tenter d'atteindre l'Active Directory ainsi que les ressources disposant de droits élevés.

Chemin d'attaque

Phishing
→ Vol d'identifiants
→ Compromission du compte administrateur
→ Accès à l'Active Directory

Biens supports concernés

- **Poste de travail de l'administrateur**
- **Compte administrateur**
- **Active Directory**
- **Serveurs**

Vulnérabilités prérequises

- **Sensibilisation insuffisante au phishing**
- **Compromission possible des identifiants**
- **Absence de généralisation du MFA aux comptes concernés**
- **Privilèges associés au compte compromis**

Conséquences

- **Compromission de l'Active Directory**

- **Accès non autorisé aux ressources**
- **Compromission de données**
- **Possibilité de propagation d'une attaque par rançongiciel**

Mesures de sécurité

- **Généralisation du MFA**
- **Sensibilisation au phishing**
- **Comptes d'administration dédiés**
- **Journalisation des accès**
- **Supervision des comptes à privilèges**

Évaluation

Élément	**Évaluation**
Scénario stratégique associé	**S2 – Compromission d'un compte administrateur**
Gravité	**G4 – Critique**
Niveau de risque	**Critique**

5.2 Scénario opérationnel 2 – Attaque par rançongiciel

Mode opératoire

Un attaquant compromet un poste utilisateur, notamment par l'intermédiaire d'un fichier ou d'un contenu malveillant.

Le logiciel malveillant cherche ensuite à accéder aux ressources accessibles depuis le poste compromis et à chiffrer les données ou rendre indisponibles les ressources nécessaires aux activités de BioMarket.

Chemin d'attaque

Compromission d'un poste utilisateur → propagation vers les ressources accessibles → chiffrement / indisponibilité → interruption des activités

Biens supports concernés

- Poste utilisateur
- Réseau
- Serveurs
- Applications métiers
- Données métiers

Vulnérabilités prérequises

- Erreur humaine
- Droits d’accès trop importants
- Protections des postes insuffisantes
- Possibilités de propagation vers les ressources internes

Conséquences

- Indisponibilité des applications métiers
- Chiffrement des données
- Interruption des ventes
- Perturbation de la gestion des stocks
- Indisponibilité des données nécessitant une restauration

Mesures de sécurité

- Déploiement d’un EDR
- Segmentation du réseau
- Mise à jour des systèmes
- Limitation des droits d’accès
- Mise en place de mécanismes de sauvegarde
- Tests de restauration
- Sensibilisation des utilisateurs

Évaluation

Élément	**Évaluation**
Scénario stratégique associé	**S4 – Attaque par rançongiciel**
Gravité	**G4 – Critique**

5.3 Scénario opérationnel 3 – Fuite de données personnelles

Mode opératoire

Une erreur de manipulation, une mauvaise configuration ou une gestion inadaptée des habilitations permet à une personne non autorisée d'accéder à des données personnelles.

Les données concernées peuvent notamment être les données clients ou les données relatives aux ressources humaines.

Chemin d'attaque

Mauvaise gestion des habilitations / erreur humaine → accès non autorisé → données personnelles → divulgation

Biens supports concernés

- Comptes utilisateurs
- Serveurs
- Applications métiers
- Données clients
- Données RH

Vulnérabilités prérequises

- Gestion insuffisante des habilitations
- Absence de revue régulière des droits
- Contrôle des accès insuffisant
- Erreur humaine

Conséquences

- Violation de données personnelles
- Non-conformité au RGPD
- Atteinte à la réputation de BioMarket
- Risques de sanctions financières

Mesures de sécurité

- Revue périodique des habilitations
- Classification des données
- Contrôle des accès
- Chiffrement des données sensibles
- Sensibilisation des utilisateurs

Rôle du DPO : contribution à la définition des mesures de protection des données personnelles, à l'analyse des impacts en matière de protection des données et au suivi de la conformité au RGPD.

Évaluation

Élément	**Évaluation**
Scénario stratégique associé	**S3 – Fuite de données personnelles**
Gravité	**G4 – Critique**

5.4 Scénario opérationnel 4 – Compromission d'un prestataire

Mode opératoire

Un attaquant compromet les identifiants d'un intervenant d'Iron4Software et tente d'utiliser les accès autorisés afin d'accéder aux informations ou aux environnements liés au projet e-commerce.

Le scénario repose sur l'exploitation de la relation de confiance entre BioMarket et son prestataire.

Chemin d'attaque

Compromission d'un compte prestataire → utilisation des accès autorisés → accès au projet e-commerce → compromission ou fuite d'informations

Biens supports concernés

- Compte du prestataire
- Accès aux environnements du projet
- Plateforme e-commerce
- Échanges entre BioMarket et Iron4Software
- Informations liées au projet

Vulnérabilités prérequises

- Compte prestataire compromis
- Contrôle insuffisant des accès tiers
- Privilèges excessifs
- Dépendance à un prestataire externe

Conséquences

- Compromission du projet e-commerce
- Divulgation d'informations sensibles
- Modification non autorisée d'éléments du projet
- Retard ou perturbation du projet

- Atteinte à l'image de BioMarket

Mesures de sécurité

- MFA obligatoire pour les accès prestataires
- Limitation des privilèges
- Contrôle des accès tiers
- Journalisation des accès
- Revue régulière des habilitations
- Clauses contractuelles de sécurité

Évaluation

Élément	**Évaluation**
Scénario stratégique associé	**S1 – Compromission d'Iron4Software**
Gravité	**G3 – Grave**

5.5 Évaluation de la vraisemblance

La vraisemblance des scénarios opérationnels est évaluée selon la méthode express, en prenant en compte la **probabilité de succès de l'attaque** et sa **difficulté technique**. Le croisement de ces deux critères permet de déterminer le niveau de vraisemblance selon la matrice retenue.

Probabilité de succès ↓ / Difficulté technique →	**1. Faible**	**2. Modérée**	**3. Élevée**	**4. Très élevée**
4. Quasi-certaine	**V4**	**V3**	**V3**	**V2**
3. Très significative	**V3**	**V3**	**V2**	**V2**
2. Significative	**V3**	**V2**	**V2**	**V1**
1. Faible	**V2**	**V2**	**V1**	**V1**

Principe : la vraisemblance globale du scénario est obtenue en croisant la probabilité de succès de l'attaque avec la difficulté technique nécessaire à sa réalisation.

Cette matrice est ensuite appliquée aux quatre scénarios opérationnels afin de déterminer leur niveau de vraisemblance **V1 à V4**.

Scénario	**Probabilité de succès**	**Justification**	**Difficulté technique**	**Justification**	**Vraisemblance**
OP1 – Compromission	**3 – Très significative**	Le phishing constitue un moyen	**2 – Modérée**	L'attaque nécessite des compétences	**V3 – Très vraisemblable**

Scénario	Probabilité de succès	Justification	Difficulté technique	Justification	Vraisemblance
d'un compte administrateur		d'attaque courant et l'obtention d'identifiants administrateurs permet d'accéder à des ressources fortement privilégiées.		techniques limitées à modérées, notamment pour le phishing et l'utilisation d'identifiants compromis.	
OP2 – Attaque par rançongiciel	**3 – Très significative**	Les postes utilisateurs constituent une porte d'entrée potentielle et une compromission peut permettre une propagation vers les ressources internes.	**2 – Modérée**	La mise en œuvre d'un rançongiciel ne nécessite pas nécessairement des compétences techniques très élevées, notamment lorsque des outils ou logiciels malveillants existants sont utilisés.	**V3 – Très vraisemblable**
OP3 – Fuite de données personnelles	**2 – Significative**	Le scénario peut résulter d'une erreur humaine ou d'une mauvaise gestion des habilitations, mais nécessite un accès aux données concernées.	**2 – Modérée**	L'exploitation d'une mauvaise configuration ou d'habilitations inadaptées reste techniquement accessible, sans nécessiter une attaque particulièrement complexe.	**V2 – Vraisemblable**
OP4 – Compromission d'un prestataire	**3 – Très significative**	Iron4Software constitue une partie prenante critique et dispose d'accès liés au projet e-commerce, ce qui rend l'exploitation d'un compte compromis	**2 – Modérée**	L'attaquant peut exploiter des accès légitimes déjà disponibles au prestataire, limitant ainsi la complexité technique nécessaire.	**V3 – Très vraisemblable**

Scénario	Probabilité de succès	Justification	Difficulté technique	Justification	Vraisemblance
		particulièrement pertinente.			

Les niveaux obtenus sont donc :

- **OP1 : V3 – Très vraisemblable**
- **OP2 : V3 – Très vraisemblable**
- **OP3 : V2 – Vraisemblable**
- **OP4 : V3 – Très vraisemblable**

Conclusion de l'atelier 4

L'analyse des scénarios opérationnels permet de préciser les principaux modes d'attaque susceptibles d'affecter BioMarket. Les scénarios les plus vraisemblables concernent la **compromission d'un compte administrateur**, l'**attaque par rançongiciel** et la **compromission d'un prestataire**. La **fuite de données personnelles** constitue également un scénario significatif en raison de la sensibilité des données traitées.

Les principales mesures identifiées concernent notamment le **MFA**, la **gestion des habilitations**, la **sensibilisation des utilisateurs**, la **segmentation réseau**, l'**EDR**, la **journalisation** et le **contrôle des accès des prestataires**.

Les résultats de cet atelier serviront de base à l'**atelier 5 – Traitement des risques**, afin de définir les mesures de sécurité prioritaires et de réduire les risques identifiés.

6. Atelier 5 – Traitement des risques

Objectif de l'atelier

L'atelier 5 a pour objectif de définir une stratégie de traitement des risques identifiés lors des ateliers précédents et d'identifier les risques résiduels après mise en œuvre des mesures de sécurité.

Les risques sont classés selon leur niveau de criticité afin de déterminer les priorités de traitement.

Les différentes options de traitement retenues sont :

- **réduire** le risque par la mise en œuvre de mesures de sécurité ;
- **transférer ou partager** le risque lorsqu'une partie du risque peut être prise en charge par un tiers ;
- **éviter** le risque lorsque l'activité à l'origine du risque peut être supprimée ;
- **accepter** le risque lorsque son niveau résiduel est jugé acceptable.

Cette approche est conforme aux principes de traitement présentés dans le cours.

6.1 Évaluation des risques

Les risques identifiés lors des ateliers précédents sont évalués selon leur **vraisemblance** et leur **gravité**. Le croisement de ces deux critères permet de déterminer le niveau de risque et de définir les priorités de traitement.

Risque	Vraisemblance	Gravité	Niveau de risque	Priorité
Compromission d'un compte administrateur	**V3 – Très vraisemblable**	**G4 – Critique**	**Critique**	**1**
Attaque par rançongiciel	**V3 – Très vraisemblable**	**G4 – Critique**	**Critique**	**2**
Compromission d'Iron4Software	**V3 – Très vraisemblable**	**G3 – Grave**	**Critique**	**3**
Fuite de données personnelles	**V2 – Vraisemblable**	**G4 – Critique**	**Élevé**	**4**

Cette hiérarchisation permet de concentrer en priorité les efforts de traitement sur les risques présentant le niveau de criticité le plus important. Elle reprend les résultats des scénarios stratégiques et opérationnels précédemment analysés.

6.2 Stratégies de traitement

À partir des niveaux de risques identifiés en 6.1, une stratégie de traitement adaptée à chaque risque est définie. L'objectif principal est de **réduire le niveau de risque** en mettant en place des mesures de sécurité proportionnées.

Risque	Niveau	Stratégie de traitement	Mesures principales
Compromission d'un compte administrateur	Critique	**Réduire**	Généralisation du MFA, comptes d'administration dédiés, revue des habilitations, journalisation et sensibilisation au phishing
Attaque par rançongiciel	Critique	**Réduire**	EDR, segmentation réseau, mises à jour, limitation des droits, sauvegardes et tests de restauration
Compromission d'Iron4Software	Critique	**Réduire / Partager**	MFA, contrôle des accès prestataires, limitation des privilèges, journalisation et exigences contractuelles
Fuite de données personnelles	Élevé	**Réduire**	Revue des habilitations, contrôle des accès, classification et protection des données, sensibilisation, implication du DPO pour les aspects liés aux données personnelles et au RGPD.

La stratégie privilégiée pour BioMarket est la **réduction du risque**, compte tenu de la criticité des scénarios identifiés. Le partage du risque est également retenu pour **Iron4Software**, en raison de la dépendance de BioMarket vis-à-vis de ce prestataire et de la nécessité d'intégrer des exigences de sécurité dans la relation contractuelle.

Cette approche permet d'agir prioritairement sur les risques critiques tout en tenant compte des responsabilités partagées avec les parties prenantes externes.

6.3 Plan de traitement des risques

Le plan de traitement traduit les stratégies retenues en **actions concrètes**, avec un responsable, une priorité et un indicateur permettant de suivre leur mise en œuvre.

Risque	Action de traitement	Responsable	Priorité	Indicateur
Compromission d'un compte administrateur	Généraliser le MFA et renforcer la protection des comptes privilégiés	DSI	**Haute**	% de comptes privilégiés protégés par MFA
Attaque par rançongiciel	Déployer un EDR sur les postes et serveurs concernés	DSI	**Haute**	% d'équipements couverts

Risque	Action de traitement	Responsable	Priorité	Indicateur
Attaque par rançongiciel	Mettre en place une politique de sauvegarde et réaliser des tests de restauration	DSI	**Haute**	Taux de tests de restauration réussis
Attaque par rançongiciel	Renforcer la segmentation réseau	DSI	**Haute**	Nombre de segments/VLAN sécurisés
Fuite de données personnelles	Réaliser une revue périodique des habilitations	DSI / RH	**Haute**	% de comptes revus
Fuite de données personnelles	Renforcer la classification et la protection des données sensibles	DSI / DPO	**Haute**	% de données sensibles classifiées
Compromission du prestataire	Imposer le MFA et contrôler les accès d'Iron4Software	DSI	**Haute**	% d'accès prestataires contrôlés
Compromission du prestataire	Intégrer les exigences de sécurité dans les relations contractuelles	Direction / DSI	**Moyenne**	% de contrats intégrant les exigences SSI
Erreurs humaines	Déployer le programme de sensibilisation	DSI / RH	**Moyenne**	% d'utilisateurs sensibilisés
Surveillance	Mettre en place une journalisation centralisée et une supervision adaptée	DSI	**Moyenne**	% de systèmes intégrés à la supervision

Le plan de traitement devra être **validé par la Direction avant sa mise en œuvre**. Son suivi permettra ensuite de mesurer l'avancement des actions et d'évaluer la réduction effective des risques.

6.4 Risques résiduels

Après la mise en œuvre des mesures de sécurité prévues dans le plan de traitement, certains risques peuvent subsister. La réduction du risque ne permet en effet pas de supprimer totalement l'exposition de BioMarket.

Les principaux risques résiduels identifiés sont les suivants :

- les **erreurs humaines**, malgré les actions de sensibilisation ;
- l'**évolution permanente des cybermenaces** ;
- la **dépendance vis-à-vis de certains prestataires** ;
- les **vulnérabilités inconnues**, notamment les vulnérabilités de type *zero-day* ;

- les risques liés à la **compromission d'un service ou d'un fournisseur externe**.

Ces risques devront être réévalués régulièrement afin de vérifier qu'ils restent compatibles avec les critères d'acceptation des risques définis dans la PSSI de BioMarket.

6.5 Suivi des actions

La mise en œuvre du plan de traitement est suivie dans le cadre de la **gouvernance du SMSI**. Chaque action fait l'objet d'un suivi permettant de vérifier son avancement et son efficacité.

Chaque action est associée à :

- un **responsable** ;
- une **échéance** ;
- un **niveau de priorité** ;
- un **indicateur de suivi** ;
- un **état d'avancement**.

Le pilotage du dispositif associe notamment la **Direction Générale, la DSI, les RH, le DPO, les responsables métiers, le consultant cybersécurité et Iron4Software**. Le DPO intervient particulièrement sur les sujets liés à la protection des données personnelles et à la conformité RGPD.

Les résultats du suivi permettent d'alimenter l'**amélioration continue du SMSI** et de réévaluer les risques lorsque le contexte ou les mesures de sécurité évoluent.

Tableau de suivi

Élément suivi	**Responsable principal**	**Indicateur**
Protection des comptes privilégiés	DSI	% de comptes protégés par MFA
Protection contre les rançongiciels	DSI	% d'équipements couverts par EDR
Sauvegardes et restauration	DSI	Taux de tests de restauration réussis
Gestion des habilitations	DSI / RH	% de comptes revus
Protection des données sensibles	DSI / DPO	% de données sensibles classifiées
Accès prestataires	DSI	% d'accès prestataires contrôlés
Sensibilisation	DSI / RH	% d'utilisateurs sensibilisés
Supervision	DSI	% de systèmes intégrés à la supervision

Ce suivi permet ainsi à BioMarket de vérifier la réalisation des actions, de mesurer leur efficacité et d'assurer une amélioration continue de la sécurité du SMSI.

6.6 Conclusion

L'Atelier 5 a permis de définir les modalités de traitement des risques identifiés lors des ateliers précédents et de prioriser les actions de sécurité à mettre en œuvre.

Les risques liés à la **compromission d'un compte administrateur**, à l'**attaque par rançongiciel** et à la **compromission d'Iron4Software** constituent les principales priorités en raison de leur niveau de risque critique. La **fuite de données personnelles** représente également un risque important qui nécessite la mise en place de mesures adaptées.

La stratégie retenue repose principalement sur la **réduction des risques**, au travers notamment du renforcement de l'authentification, de la gestion des habilitations, de la protection des postes et serveurs, de la segmentation réseau, des sauvegardes, de la supervision et de la sensibilisation des utilisateurs. La sécurité des accès des prestataires, notamment Iron4Software, doit également être renforcée et encadrée contractuellement.

Le plan de traitement permet d'associer chaque mesure à un responsable, une priorité et un indicateur de suivi. Les risques résiduels devront être régulièrement réévalués afin de vérifier l'efficacité des mesures mises en œuvre et d'adapter le dispositif de sécurité en fonction de l'évolution des menaces.

Ainsi, l'Atelier 5 permet de passer de l'analyse des risques à une **démarche concrète de réduction et de suivi des risques**, intégrée dans le fonctionnement du SMSI de BioMarket.

7. Matrice des risques

Cette partie permet de visualiser et de hiérarchiser les risques identifiés lors des ateliers précédents. La matrice est construite à partir des niveaux de **vraisemblance (V1 à V4)** et de **gravité (G1 à G4)** retenus dans l'analyse.

7.1 Échelle de vraisemblance

Niveau	Vraisemblance	Description
V4	Quasi-certain	Événement dont la réalisation est très probable
V3	Très vraisemblable	Événement probable compte tenu des menaces et des vulnérabilités identifiées
V2	Vraisemblable	Événement plausible pouvant se produire dans certaines circonstances
V1	Peu vraisemblable	Événement peu probable dans les conditions actuelles

Cette échelle reprend les niveaux de vraisemblance utilisés lors de l'Atelier 4 et de l'évaluation des scénarios opérationnels.

7.2 Échelle de gravité

Niveau	Gravité	Description
G4	Critique	Incapacité à assurer tout ou partie de l'activité, avec des impacts graves sur les personnes, les biens ou la pérennité de l'organisation
G3	Grave	Forte dégradation des performances de l'activité, avec des impacts significatifs et un fonctionnement en mode très dégradé
G2	Significative	Dégradation des performances de l'activité sans impact majeur ; fonctionnement possible en mode dégradé
G1	Mineure	Absence d'impact opérationnel significatif ; situation absorbable par l'organisation

L'échelle de gravité est celle retenue précédemment dans l'analyse des événements redoutés de BioMarket.

7.3 Matrice de criticité

Le niveau de risque est déterminé par le croisement de la **vraisemblance** et de la **gravité**.

Gravité \ Vraisemblance	V1 Peu vraisemblable	V2 Vraisemblable	V3 Très vraisemblable	V4 Quasi-certain
G4 Critique	Modéré	Élevé	**Critique**	**Critique**
G3 Grave	Modéré	Élevé	**Critique**	**Critique**
G2 Significative	Faible	Modéré	Élevé	**Critique**
G1 Mineure	Faible	Faible	Modéré	Élevé

Cette matrice permet de prioriser les actions de traitement en fonction de la combinaison entre la probabilité de réalisation du scénario et la gravité de ses conséquences.

7.4 Positionnement des risques BioMarket

Les quatre risques principaux identifiés lors de l'analyse sont positionnés dans la matrice comme suit :

Risque	Vraisemblance	Gravité	Niveau de risque	Priorité
Compromission d'un compte administrateur	**V3 – Très vraisemblable**	**G4 – Critique**	**Critique**	**1**
Attaque par rançongiciel	**V3 – Très vraisemblable**	**G4 – Critique**	**Critique**	**2**
Compromission d'Iron4Software	**V3 – Très vraisemblable**	**G3 – Grave**	**Critique**	**3**
Fuite de données personnelles	**V2 – Vraisemblable**	**G4 – Critique**	**Élevé**	**4**

Ces évaluations sont cohérentes avec la hiérarchisation réalisée dans l'Atelier 5 : les trois premiers risques constituent les priorités principales de traitement, tandis que la fuite de données personnelles demeure un risque important nécessitant également des mesures de réduction.

8. Registre des risques

8.1 Registre des risques

Le registre des risques permet de centraliser les principaux risques identifiés lors de l'analyse EBIOS Risk Manager, leur niveau de vraisemblance et de gravité, les mesures de traitement associées ainsi que leur niveau résiduel cible.

ID	Risque	Vraisemblance initiale	Gravité	Niveau initial	Mesures de traitement	Risque résiduel cible	Responsable
R1	Compromission d'un compte administrateur	**V3 – Très vraisemblable**	**G4 – Critique**	**Critique**	MFA, comptes administrateurs dédiés, revue des habilitations, journalisation, sensibilisation au phishing	**Modéré**	DSI
R2	Attaque par rançongiciel	**V3 – Très vraisemblable**	**G4 – Critique**	**Critique**	EDR, segmentation réseau, limitation des droits, sauvegardes, tests de restauration, sensibilisation	**Modéré**	DSI
R3	Compromission d'Iron4Software	**V3 – Très vraisemblable**	**G3 – Grave**	**Critique**	MFA, contrôle des accès prestataires, limitation des privilèges, journalisation, revue des accès, clauses de sécurité	**Modéré**	DSI / Direction
R4	Fuite de données personnelles	**V2 – Vraisemblable**	**G4 – Critique**	**Élevé**	Revue des habilitations, contrôle des accès, classification et protection des données, sensibilisation	**Faible à modéré**	DSI / RH / DPO

Les risques R1, R2 et R3 constituent les principales priorités de traitement, avec un niveau initial critique. R4 présente un niveau initial élevé et fait également l'objet de mesures de réduction. Les mesures retenues correspondent au plan de traitement défini précédemment.

8.2 Suivi du registre

Le registre des risques constitue un outil de suivi du traitement des risques du SMSI. Il est mis à jour lors des revues de sécurité et lors de toute évolution significative du contexte, des systèmes d'information ou des menaces.

Pour chaque risque, les mesures de traitement sont suivies par un responsable identifié et associées à des indicateurs permettant de mesurer leur avancement et leur efficacité.

Les risques résiduels sont réévalués après la mise en œuvre des mesures afin de vérifier leur conformité aux critères d'acceptation définis dans la PSSI de BioMarket. Dans le cas contraire, des mesures complémentaires doivent être définies.

9. Conclusion

L'analyse des risques menée selon la méthode **EBIOS Risk Manager** a permis d'identifier et de hiérarchiser les principaux risques susceptibles d'affecter les activités et le système d'information de BioMarket.

Les principaux risques identifiés concernent notamment la **compromission des comptes administrateurs**, les **attaques par rançongiciel**, la **compromission du prestataire Iron4Software** et la **fuite de données personnelles**.

L'analyse a également permis de définir et de prioriser les principales mesures de traitement, notamment la **généralisation de l'authentification multifacteur**, le renforcement de la **gestion des habilitations**, la protection des postes et serveurs, la **segmentation du réseau**, les mécanismes de **sauvegarde et de restauration**, la sensibilisation des utilisateurs et le contrôle des accès des prestataires.

Le registre des risques permet de suivre la mise en œuvre de ces actions et leur efficacité. Les **risques résiduels devront être réévalués** après la mise en œuvre effective des mesures afin de vérifier qu'ils restent compatibles avec les critères d'acceptation définis par BioMarket.

Cette analyse constitue ainsi une base pour la **priorisation des mesures de sécurité** et contribue à l'amélioration continue du **SMSI de BioMarket**.